

15 · Riesgos y deuda técnica

Documentacion del sistema

Version analizada: **0.1.0**

Commit analizado: **5e91229**

Fecha de generacion: **2026-08-27**

Generado a partir de 15-risks-and-technical-debt.md — los Markdown son la fuente unica.
No editar este PDF: editar el Markdown y regenerar.

Contenido de este documento

1. Cómo se clasifica
2. Resumen
3. Severidad alta
4. Severidad media
5. Severidad baja
6. Informativos
7. Lo que se buscó y ****no**** se encontró
8. Decisiones que requieren validación humana
9. Elementos no verificados en este análisis

Registro de hallazgos de este análisis, clasificados por severidad, impacto, probabilidad y evidencia. **Documento informativo: ningún hallazgo se corrigió automáticamente.** El único cambio en el código de este análisis fue añadir 71 líneas de comentarios de documentación.

1. Cómo se clasifica

Campo	Valores
Severidad	Crítica · Alta · Media · Baja · Informativa
Impacto	Qué pasa si se materializa
Probabilidad	Alta · Media · Baja
Prioridad	P1 (antes de la siguiente release) · P2 (corto plazo) · P3 (cuando toque) · P4 (opcional)

La severidad refleja el efecto sobre la **función del producto** —detectar y explicar— no solo sobre el código.

2. Resumen

Severidad	Hallazgos	Prioridad más alta
Crítica	0	—
Alta	3	P1
Media	9	P2
Baja	8	P3
Informativa	4	P4
Total	24	—

No se encontró ningún fallo que comprometa la corrección de la detección con la configuración por defecto. Los tres hallazgos altos son un límite estructural del enfoque, una acción irreversible sin red de seguridad y una exposición transitoria de credencial.

3. Severidad alta

R-01 · Aceptar una baseline es irreversible

Campo	Valor
Severidad	Alta
Impacto	Un hallazgo real aceptado por error deja de reportarse para siempre. La única salida es borrar el SQLite, lo que destruye también el historial y la auditoría
Probabilidad	Media: la aceptación está a un clic y a un -accept

Evidencia	<code>replace_</code> <code>persistence_</code> <code>baseline</code> y <code>replace_baseline</code> hacen <code>DELETE + INSERT</code> sin conservar la versión anterior; no existe ninguna función de deshacer
Ubicación	<code>src/services/</code> <code>persistence.rs</code> , <code>src/services/</code> <code>inspector.rs::</code> <code>accept_*_baseline</code>
Recomendación	Versionar la baseline: una tabla <code>baseline_history</code> con la foto anterior y un comando <code>rootcause baseline --undo</code> . Alternativa mínima: volcar la baseline saliente a un JSON en la carpeta de datos antes de reemplazarla
Prioridad	P1

R-02 · La primera baseline se siembra en silencio

Campo	Valor
Severidad	Alta
Impacto	Si el equipo ya está comprometido al instalar RootCause, la persistencia del atacante queda registrada como «estado bueno conocido» y nunca se reporta como cambio
Probabilidad	Baja en un equipo sano; alta en el escenario en que más se necesitaría la herramienta
Evidencia	<code>baseline::diff_</code> <code>surface</code> : si la baseline está vacía, la siembra y devuelve <code>false</code> sin generar eventos. Está documentado como decisión deliberada
Ubicación	<code>src/services/</code> <code>baseline.rs</code> , <code>src/services/</code> <code>inspector.rs::diff</code> <code>_persistence_</code> <code>baseline</code>
Recomendación	Mitigación parcial, no eliminación: en la primera captura, listar en un aviso destacado las entradas que por sí solas tienen riesgo alto o crítico, aunque no sean «cambios». Los datos ya existen (<code>classify_entry</code> los puntúa); solo falta presentarlos como «revisión inicial obligatoria»
Prioridad	P1
Nota	El propio <code>README.md</code> reconoce el enfoque; lo que falta es la revisión inicial, no un cambio de diseño

R-03 · La clave de la IA es visible en la lista de procesos

Campo	Valor
Severidad	Alta (condicionada: solo si el usuario activa la IA)
Impacto	Cualquier usuario del equipo puede leer la clave con <code>ps</code> mientras dura la petición
Probabilidad	Baja: requiere IA activada y un observador local en la ventana de la petición

Evidencia	<code>ai::post_json</code> pasa - H "Authorization: Bearer <clave>" como argumento de <code>curl</code> . El cuerpo sí se protege por <code>stdin</code> , con comentario que explica esa protección
Ubicación	<code>src/services/ai.rs</code> <code>::post_json</code>
Recomendación	Pasar las cabeceras también por <code>stdin</code> (<code>--header @-</code> con <code>-K -</code> o un archivo de configuración temporal con permisos 600)
Prioridad	P1

4. Severidad media

R-04 · Cinco campos de configuración no tienen ningún efecto

Campo	Valor
Severidad	Media
Impacto	El usuario configura algo que no ocurre. Es peor que no ofrecerlo: genera una falsa sensación de control
Probabilidad	Alta: aparecen en el JSON que genera <code>config init</code>
Evidencia	<code>grep</code> fuera de <code>src/config.rs</code> no devuelve ninguna lectura de <code>anomaly.suspicious</code> <code>_parent_names</code> , <code>anomaly.shell_interpreters</code> , <code>ui.daily_report</code> , <code>alerting.notification_cooldown_secs</code> ni <code>resilience.stale_after_secs</code>
Ubicación	<code>src/config.rs</code>
Recomendación	Implementarlos o retirarlos. Los dos primeros corresponden a heurísticas de linaje de proceso que el módulo de anomalías aún no cubre; <code>notification_cooldown_secs</code> es el más barato de implementar y el que más ruido evita
Prioridad	P2

R-05 · Las notificaciones críticas pueden repetirse en cada captura

Campo	Valor
Severidad	Media
Impacto	Con una condición crítica persistente y refresco de 5 s, el centro de notificaciones se llena. Un usuario saturado deja de leer las alertas
Probabilidad	Alta cuando hay un hallazgo crítico real
Evidencia	<code>notify_if_critical</code> no consulta ningún estado previo; <code>notification_cooldown_secs</code> existe y no se lee

Ubicación	<code>src/services/inspector.rs::notify_if_critical</code>
Recomendación	Guardar la marca de tiempo y la huella de la última notificación y respetar el cooldown configurado
Prioridad	P2

R-06 · No hay migraciones de esquema

Campo	Valor
Severidad	Media
Impacto	Añadir una columna a una tabla existente no se aplicará en instalaciones ya creadas: <code>CREATE TABLE IF NOT EXISTS</code> no altera nada. El síntoma sería un error de columna inexistente en tiempo de ejecución
Probabilidad	Media: ocurrirá en cuanto el esquema evolucione
Evidencia	<code>ensure_schema</code> solo contiene <code>CREATE TABLE IF NOT EXISTS</code> y un <code>CREATE INDEX IF NOT EXISTS</code>
Ubicación	<code>src/services/persistence.rs::ensure_schema</code>
Recomendación	Añadir <code>PRAGMA user_version</code> y una función <code>migrate()</code> con pasos numerados. Es barato ahora y caro después
Prioridad	P2

R-07 · `audit_log` crece sin límite

Campo	Valor
Severidad	Media
Impacto	El archivo SQLite crece indefinidamente en instalaciones de larga duración
Probabilidad	Media
Evidencia	<code>trim_table</code> solo se llama con <code>"snapshots"</code> e <code>"incidents"</code>
Ubicación	<code>src/services/persistence.rs</code>
Recomendación	Decidir explícitamente: o un límite alto configurable, o una rotación a archivo externo. No recortarla en silencio : es evidencia
Prioridad	P2

R-08 · La auditoría es alterable por quien pueda escribir en el archivo

Campo	Valor
-------	-------

Severidad	Media
Impacto	Un atacante con acceso al usuario puede borrar el rastro de sus acciones y de las baselines aceptadas
Probabilidad	Baja, pero es exactamente el escenario que la herramienta pretende cubrir
Evidencia	La tabla vive en el mismo SQLite del usuario, sin firma ni cadena de hashes
Ubicación	<code>src/services/persistence.rs</code>
Recomendación	Cadena de hashes encadenados por fila (cada registro incluye el hash del anterior). No impide el borrado, pero lo hace detectable
Prioridad	P2

R-09 · La huella de configuración no es criptográfica

Campo	Valor
Severidad	Media
Impacto	Un cambio malicioso que preserve tamaño y fecha (<code>touch</code>) pasa inadvertido
Probabilidad	Baja
Evidencia	<code>config_fingerprint</code> devuelve <code>format!("{}", len, modified)</code> . El código lo declara abiertamente y explica por qué no promete más
Ubicación	<code>src/services/resilience.rs::config_fingerprint</code>
Recomendación	SHA-256 del contenido. Requiere una dependencia nueva o una implementación propia; valorar si compensa frente a la política de cero dependencias
Prioridad	P2

R-10 · No se comprueba que el endpoint de IA sea HTTPS

Campo	Valor
Severidad	Media
Impacto	Un <code>ai.endpoint</code> con <code>http://</code> enviaría el incidente y la clave en claro
Probabilidad	Baja: exige que el usuario lo configure así
Evidencia	La única validación de <code>endpoint</code> es que no esté vacío
Ubicación	<code>src/services/ai.rs::summarize_incident</code>

Recomendación	Rechazar cualquier esquema distinto de <code>https://</code> , salvo <code>localhost</code> para pruebas
Prioridad	P2

R-11 · Los umbrales no se validan entre sí

Campo	Valor
Severidad	Media
Impacto	Con <code>cpu_critical_percent < cpu_warning_percent</code> , la rama de aviso es inalcanzable y el usuario cree tener dos niveles cuando solo tiene uno
Probabilidad	Baja
Evidencia	<code>classify_process</code> evalúa primero la rama crítica; no hay validación en <code>load_or_default</code>
Ubicación	<code>src/config.rs</code> , <code>src/services/rules.rs::classify_process</code>
Recomendación	Validar al cargar y emitir una advertencia como la de JSON inválido, que ya existe y es el mecanismo adecuado
Prioridad	P2

R-12 · `app.rs` concentra 2 750 líneas

Campo	Valor
Severidad	Media
Impacto	Dificulta la revisión y las modificaciones; concentra el 21 % del código del proyecto en un archivo
Probabilidad	Alta (ya ocurre)
Evidencia	<code>wc -l src/app.rs = 2 750</code> ; contiene paleta, hilo de trabajo, navegación, doce secciones y veinte widgets
Ubicación	<code>src/app.rs</code>
Recomendación	División natural sin cambiar comportamiento: <code>app/worker.rs</code> (canales y hilo), <code>app/theme.rs</code> (paleta y estilo), <code>app/widgets.rs</code> (widgets comunes) y <code>app/views/*.rs</code> (una por sección)
Prioridad	P2

5. Severidad baja

R-13 · `static mut` para la paleta activa

Campo	Valor
-------	-------

Severidad	Baja
Impacto	Único <code>unsafe</code> del proyecto. Correcto mientras solo lo use el hilo de interfaz, pero es una invariante no verificada por el compilador
Evidencia	<code>static mut ACTIVE_</code> DARK: <code>bool</code> en <code>src/app.rs</code> , con comentario <code>SAFETY</code>
Recomendación	Sustituir por <code>AtomicBool</code> (como ya hace <code>i18n.rs</code> con el idioma) o por <code>thread_local!</code> . El coste es nulo y elimina el <code>unsafe</code>
Prioridad	P3

R-14 · `expand_home` y `bytes_to_mb` están duplicadas

Campo	Valor
Severidad	Baja
Impacto	Dos implementaciones idénticas que podrían divergir
Evidencia	<code>expand_home</code> en <code>launchd.rs</code> y <code>temp_scan.rs</code> ; <code>bytes_to_mb</code> en <code>inspector.rs</code> y <code>temp_scan.rs</code>
Recomendación	Moverlas a un módulo <code>util</code> o a <code>macos.rs</code>
Prioridad	P3

R-15 · Sin `cargo audit` en la CI

Campo	Valor
Severidad	Baja
Impacto	Una vulnerabilidad publicada en cualquiera de las 326 dependencias pasaría inadvertida
Evidencia	<code>ci.yml</code> no incluye el paso; no hay <code>deny.toml</code> ni <code>audit.toml</code>
Recomendación	Añadir un paso <code>cargo audit</code> y, opcionalmente, <code>cargo deny</code>
Prioridad	P3
Nota	El repositorio hermano <code>rootcause-server</code> sí incluye <code>deny.toml</code>

R-16 · Acciones de CI y `markdownlint-cli2` sin fijar

Campo	Valor
Severidad	Baja
Impacto	<code>npx --yes markdownlint-cli2</code> descarga la última versión en cada ejecución: una versión nueva con reglas nuevas puede romper la CI sin que cambie el repositorio
Evidencia	<code>.github/workflows/ci.yml</code>

Recomendación	Fijar <code>markdownlint-cli2@<versión></code> y, si se quiere ir más lejos, las acciones por SHA
Prioridad	P3

R-17 · Sin cobertura de tests medida

Campo	Valor
Severidad	Baja
Impacto	No hay forma objetiva de saber si la cobertura sube o baja con cada cambio
Evidencia	No hay configuración de <code>tarpaulin</code> ni <code>llvm-cov</code>
Recomendación	<code>cargo llvm-cov</code> en la CI, sin puerta de calidad al principio
Prioridad	P3

R-18 · La orquestación y la persistencia no tienen tests

Campo	Valor
Severidad	Baja (por cobertura indirecta del humo de la CI)
Impacto	<code>collect_snapshot</code> , <code>PersistenceStore</code> y <code>diff_surface</code> sobre base real dependen de la prueba de humo
Evidencia	Ver 12 · Pruebas §6
Recomendación	Las tres pruebas de prioridad alta listadas en ese documento
Prioridad	P3

R-19 · Cask de Homebrew sin publicar

Campo	Valor
Severidad	Baja
Impacto	El <code>README</code> lo lista como «Plantilla»; un usuario podría intentar <code>brew install</code> y no encontrar nada
Evidencia	<code>packaging/homebrew/rootcause.rb</code> existe; no hay tap ni referencia a uno
Recomendación	Publicar el tap o marcarlo aún más claramente como no disponible
Prioridad	P3

R-20 · Saneado parcial del AppleScript de notificación

Campo	Valor
Severidad	Baja
Impacto	Se sustituyen comillas dobles pero no barras invertidas; un texto con <code>\"</code> podría alterar el script

Probabilidad	Muy baja: los textos los genera el propio producto, no una entrada externa
Evidencia	<code>macos::notify</code>
Recomendación	Escapar también <code>\</code> o usar el paso de argumentos de <code>osascript</code> en vez de interpolar
Prioridad	P3

6. Informativos

R-21 · Los incidentes no referencian su captura

Sin clave foránea ni columna de referencia: la relación es por marca de tiempo. Si `snapshots` recorta la fila correspondiente, el incidente queda huérfano. **Impacto real bajo** porque `payload_json` es autosuficiente. Prioridad P4.

R-22 · El CLI no valida banderas desconocidas

`rootcause status --inventada` se ejecuta ignorando la bandera. Es un comportamiento razonable para una herramienta de diagnóstico, pero podría ocultar una errata en un script. Prioridad P4.

R-23 · El CLI solo está en español

`i18n::tr` solo lo usa `app.rs`. La interfaz gráfica es bilingüe; la consola, no. Es una decisión implícita, no declarada. Prioridad P4.

R-24 · Reportes y exportes sin modo redactado

Contienen nombre de equipo, modelo, rutas de usuario e IP. Quien comparta un reporte debe revisarlo antes. Un modo `--redact` sería útil para compartir evidencia con terceros. Prioridad P4.

7. Lo que se buscó y no se encontró

Registrar lo que está bien es tan útil como registrar lo que falla:

Comprobación	Resultado
Credenciales o tokens en el repositorio	Ninguno
Ejecución de shell (<code>sh -c</code>)	Ninguna
Inyección SQL desde datos externos	Ninguna: parámetros ligados en todas las consultas con datos
Llamadas a <code>sudo</code>	Ninguna
<code>unwrap()</code> sobre entrada externa en la ruta de captura	Ninguno
<code>#[allow(...)]</code> sin justificación	Ninguno: los dos existentes están comentados
Dependencias no usadas	Ninguna
Módulos o funciones muertas	Ninguna
Ciclos de dependencia entre módulos	Ninguno
<code>--insecure</code> o verificación TLS desactivada	Ninguna

Telemetría o salida de red no declarada	Ninguna
Advertencias de <code>clippy</code>	Ninguna
Tests fallando o ignorados	Ninguno

8. Decisiones que requieren validación humana

No son fallos: son elecciones que solo el responsable del producto puede confirmar.

#	Decisión	Pregunta abierta
1	Los cinco campos de configuración sin efecto	¿Implementarlos o retirarlos? Retirarlos rompe la compatibilidad del JSON
2	Alcance del aviso inicial (R-02)	¿Un aviso destacado en la primera captura o un comando <code>rootcause review-initial</code> ?
3	Hash criptográfico de configuración (R-09)	¿Merece una dependencia nueva en un proyecto que presume de tener pocas?
4	Retención de la auditoría (R-07)	¿Límite, rotación o crecimiento indefinido asumido?
5	División de <code>app.rs</code> (R-12)	¿Ahora o cuando se añada la siguiente sección?
6	Publicación del cask (R-19)	¿Se mantiene la vía de compilación como única recomendada?
7	Firma y notarización	Requiere una cuenta de desarrollador de Apple: decisión de coste

9. Elementos no verificados en este análisis

Repetidos aquí desde la portada, con su motivo:

#	Sin verificar	Motivo
1	Lectura real de <code>TCC.db</code>	El terminal del análisis no tiene Acceso total al disco
2	Comportamiento como root	No se ejecutó con privilegios elevados
3	Consulta de login items	Dispararía un diálogo de permisos que alteraría el estado del equipo
4	Barrido activo de red	Generaría tráfico hacia 254 direcciones del segmento
5	Contrato del proveedor IA	Depende del endpoint que configure cada usuario
6	Vulnerabilidades de dependencias	<code>cargo audit</code> no ejecutado
7	Publicación real de una release	Requiere <code>gh</code> autenticado y crear una etiqueta
8	Comportamiento en macOS 13 y 14	Solo se probó en macOS 26.3.1

Siguiente lectura recomendada: [16 · Glosario](#).